

CYBERSECURITY (F26) — SDU CIS

EXAM ADDITIONS REFERENCE

Open-Book Exam Supplement · Ctrl+F Optimised

Topics Covered in This Document

TOPIC	SECTION	CONTENT
MITM & Network Interception	Section 1	ARP spoofing · DNS hijacking · SSL stripping · Tools · Defences
GDPR & Privacy Engineering	Section 2	Lawful bases · Data subject rights · PbD · Pseudonymisation
STRIDE → Mitigation + DREAD	Section 3	Full STRIDE mapping · DREAD scoring · worked examples · Attack trees
Kubernetes Threat Modelling	Section 4	4Cs · Architecture · Attack path · K8s STRIDE · Hardening

Each section: concept reference · keyword index · 10 MCQs · 10 short-answer questions

SECTION 1 — MAN-IN-THE-MIDDLE (MITM) & NETWORK INTERCEPTION

MITM ARP spoofing ARP poisoning DNS hijacking SSL stripping Ettercap Bettercap Wireshark rogue AP evil twin session hijacking ARP cache gratuitous ARP HSTS certificate pinning

■ 1.1 — What Is a Man-in-the-Middle Attack?

A **Man-in-the-Middle (MITM) attack** occurs when an attacker secretly positions themselves between two communicating parties, intercepting and optionally modifying traffic without either party's knowledge. Both parties believe they are communicating directly with each other. MITM attacks violate **Confidentiality** (attacker reads data), **Integrity** (attacker may alter data), and sometimes **Availability**. They are a foundational attack pattern for credential theft, session hijacking, and traffic manipulation.

MITM is typically a **two-phase attack**: (1) *interception* — get traffic routed through the attacker; (2) *decryption/exploitation* — extract or manipulate the intercepted data. Phase 1 uses techniques like ARP spoofing or rogue access points. Phase 2 exploits weak or absent encryption.

■ 1.2 — ARP Spoofing / ARP Poisoning

ARP (Address Resolution Protocol) maps IP addresses to MAC addresses on a LAN. ARP has **no authentication** — any host can send an ARP reply (called a **gratuitous ARP**) claiming any IP belongs to its MAC. The receiving host updates its **ARP cache** immediately with no verification.

Step	Action	Detail
1	Attacker → Victim (fake ARP reply)	Claims: 'Gateway IP is at attacker MAC AA:BB:CC'
2	Victim updates ARP cache	All traffic to gateway now goes to attacker's MAC
3	Attacker → Gateway (fake ARP reply)	Claims: 'Victim IP is at attacker MAC'
4	Gateway updates ARP cache	Gateway sends replies → attacker
5	Attacker forwards traffic	Reads/modifies all traffic. IP forwarding must be ON to stay invisible.

Key ARP spoofing facts:

- ARP operates at **Layer 2 (Data Link)** — LAN-local only, does not cross routers.
- ARP cache TTL ≈ 60–120 s on Linux, 2 min on Windows — attacker must **continuously re-send** fake replies.
- **Gratuitous ARP**: unsolicited ARP reply; used legitimately for failover but abused in ARP poisoning.
- Tools: **arp spoof** (dsniff suite), **Ettercap**, **Bettercap**.
- Wireshark detection: filter **arp.duplicate-address-detected** — two MACs claiming the same IP.
- Defence: **Dynamic ARP Inspection (DAI)** on managed switches; static ARP entries for critical hosts.

Bettercap commands: `net.probe on` → `set arp.spoof.targets <victim_IP>` → `arp.spoof on` → `net.sniff on`

■ 1.3 — DNS Hijacking / DNS Spoofing

DNS hijacking tricks a client or resolver into mapping a legitimate domain to the attacker's IP. DNS uses **UDP port 53** by default and has no authentication in its base form.

Type	Mechanism	Scope	Example
Local DNS hijacking	Malware edits <code>/etc/hosts</code> or Windows hosts file	Single machine	<code>evil.com</code> → attacker IP

Type	Mechanism	Scope	Example
Router DNS hijacking	Attacker compromises router, changes DNS server setting	All LAN users	All queries go to attacker's DNS
DNS cache poisoning	Flood resolver with forged replies before legitimate reply; guess tx ID	All resolver users	bank.com → fake bank IP
DNS-over-HTTPS bypass	Block DoH/DoT ports → fall back to plaintext → poison	Targeted user	Encrypted DNS circumvented
DNSSEC bypass	Target zones without DNSSEC validation	Non-DNSSEC zones	Resolver accepts unsigned forged record

- **TTL (Time To Live)**: low TTL = smaller poisoning window; high TTL = poisoned entry persists longer.
- **DNSSEC**: cryptographically signs DNS records. Requires both zone and resolver support.
- Wireshark filter: **dns** — check A record IPs against expected values.

■ 1.4 — SSL Stripping

SSL stripping (Moxie Marlinspike, 2009) **downgrades HTTPS to HTTP** transparently. The attacker sits between victim and server (via ARP spoof), intercepts the initial HTTP request, and maintains HTTPS to the real server while serving the victim unencrypted HTTP.

Phase	What happens
1. Victim requests http://bank.com	Plain HTTP — victim types URL or clicks link.
2. Attacker intercepts HTTP request	Attacker (MITM via ARP spoof) catches request before HTTPS redirect.
3. Attacker opens HTTPS to real server	Valid encrypted session maintained with bank.com.
4. Attacker serves victim plain HTTP	Victim sees the bank page but over unencrypted HTTP — no padlock.
5. Victim submits credentials	Username/password travel in cleartext to attacker, who forwards to bank.
6. Bank responds normally	Attacker forwards response — victim has no idea attack is occurring.

SSL stripping defences:

- **HSTS**: server header tells browser to ONLY use HTTPS for a domain for a defined period.
- **HSTS Preloading**: domain hard-coded in browser lists — no HTTP request is ever made.
- **Certificate pinning**: app hard-codes expected certificate/public key; rejects any other.

■ 1.5 — Rogue Access Point / Evil Twin

A **rogue AP** is an unauthorised WiFi AP. An **evil twin** copies a legitimate AP's **SSID** (and often signal strength) to trick devices into auto-connecting. All victim traffic passes through the attacker. Defence: **WPA-Enterprise (802.1X)** — requires certificate validation per user, so the evil twin cannot present a valid signed certificate and authentication fails.

■ 1.6 — Tools & Wireshark Detection

Tool	Primary Use	Key Commands / Notes
Ettercap	ARP spoofing, sniffing, plugin-based MITM	ettercap -T -q -i eth0 -M arp:remote /target/ /gateway/
Bettercap	Modern MITM framework — ARP, DNS, SSL strip, WiFi	bettercap -iface eth0 → net.probe on → arp.spoof on → net.sniff on
Wireshark	Packet capture & analysis, detection	Filters: arp.duplicate-address-detected / dns / http / ssl

Tool	Primary Use	Key Commands / Notes
arp spoof	Classic ARP poisoning (dsniff suite)	arp spoof -i eth0 -t victim_ip gateway_ip
sslstrip	HTTP downgrade / SSL stripping	sslstrip -l 8080 (combined with iptables redirect rule)
mitmproxy	HTTP/HTTPS interception proxy with live editing	mitmproxy -p 8080 — modify requests/responses in real time

Attack	Wireshark Filter / Indicator
ARP spoofing	arp.duplicate-address-detected OR two ARP replies with same IP but different MACs
DNS hijacking	dns.flags.response==1 — check A record IPs against known-good values
SSL stripping	HTTP traffic (port 80) to hosts that should always use HTTPS; login forms on port 80
Rogue AP	WLAN management frames: same SSID but different BSSID (MAC address)
Session hijack	Duplicate TCP sequence numbers; unexpected cookie reuse after RST

1.7 — MITM Defences Summary

Defence	Protects Against	How
Dynamic ARP Inspection (DAI)	ARP spoofing	Switch validates ARP against DHCP snooping binding table; drops fake entries
HSTS / HSTS Preloading	SSL stripping	Forces HTTPS; browser refuses all HTTP connections to enrolled domains
Certificate Pinning	SSL strip / fake cert	App rejects certificates not matching pinned public key
DNSSEC	DNS cache poisoning	Cryptographically signs DNS records; resolver validates signatures
DNS over HTTPS (DoH) / TLS (DoT)	DNS hijacking	Encrypts DNS queries — MITM cannot read or forge them
WPA-Enterprise (802.1X)	Evil twin / rogue AP	Per-user auth with server certificates; client validates AP identity
VPN	General MITM	Encrypts all traffic end-to-end; MITM sees only encrypted tunnel
Network IDS (e.g. Snort)	ARP spoof / DNS poison	Detects anomalous ARP / DNS patterns and raises alerts

SECTION 1 — MCQ PRACTICE (10 Questions)

Q1. Which OSI layer does ARP operate at?

- A. Layer 3 (Network)
- B. Layer 2 (Data Link)
- C. Layer 4 (Transport)
- D. Layer 7 (Application)

✓ **Answer: B** — ARP maps IP (L3) to MAC (L2) addresses and operates at Layer 2. It uses broadcast frames confined to a single LAN segment — routers do not forward ARP broadcasts.

Q2. An attacker sends unsolicited ARP replies claiming the gateway's IP maps to the attacker's MAC. What is this called?

- A. DNS cache poisoning

- B. TCP session hijacking
- C. Gratuitous ARP / ARP spoofing
- D. DHCP starvation

✓ **Answer: C** — Sending fake unsolicited ARP replies to poison ARP caches is ARP spoofing (gratuitous ARP abuse). ARP has no authentication, so recipients accept and cache the reply immediately.

Q3. In an SSL stripping attack, what does the attacker do to the victim's HTTPS connection?

- A. Breaks the TLS handshake with a TCP RST
- B. Downgrades it to HTTP so credentials travel in cleartext
- C. Replaces the server certificate with a self-signed one
- D. Redirects the victim to a phishing domain

✓ **Answer: B** — SSL stripping intercepts the initial HTTP request before the HTTPS redirect and maintains HTTPS only on the server side, serving the victim plain HTTP — credentials then travel in cleartext.

Q4. Which defence specifically prevents SSL stripping by ensuring a browser never makes an HTTP request to an enrolled domain?

- A. Certificate Revocation Lists (CRL)
- B. DNSSEC
- C. HSTS Preloading
- D. Dynamic ARP Inspection

✓ **Answer: C** — HSTS Preloading embeds domain lists directly in browsers. The browser enforces HTTPS before any HTTP request is ever sent — removing the interception window.

Q5. What Wireshark display filter helps detect ARP spoofing?

- A. `tcp.flags.syn==1`
- B. `arp.duplicate-address-detected`
- C. `dns.flags.response==1`
- D. `http.request.method==POST`

✓ **Answer: B** — `arp.duplicate-address-detected` flags scenarios where two different MACs claim the same IP — the hallmark signature of ARP poisoning.

Q6. Why must an ARP poisoning attacker continuously re-send fake ARP replies?

- A. To prevent the victim from running a network scan
- B. ARP cache entries expire (short TTL) and legitimate replies would correct the cache
- C. Because routers strip ARP headers every 30 seconds
- D. To increase available bandwidth

✓ **Answer: B** — ARP cache entries have short TTLs (60–120 s). Legitimate ARP replies from the real gateway periodically refresh correct entries, overwriting spoofed ones unless the attacker keeps poisoning.

Q7. An evil twin attack differs from a standard rogue AP primarily because:

- A. It uses WPA3 instead of WPA2
- B. It targets only mobile devices
- C. It clones the SSID of a legitimate network to attract automatic connections
- D. It requires physical access to the building

✓ **Answer: C** — An evil twin copies the legitimate network's SSID (and often BSSID), causing devices configured to auto-join that network to connect to the attacker instead.

Q8. Which encrypted DNS protocol most directly defends against DNS hijacking via traffic interception?

- A. DNSSEC
- B. DNS over HTTPS (DoH)

- C. ARP
- D. HSTS

✓ **Answer: B** — DoH / DoT encrypts DNS queries, preventing a MITM from reading or forging DNS responses in transit. DNSSEC validates record integrity but does not encrypt queries.

Q9. Bettercap runs 'arp.spoof on' and 'net.sniff on'. The attacker captures HTTP login credentials. Which CIA properties are violated?

- A. Integrity and Availability
- B. Confidentiality and Availability
- C. Confidentiality and Integrity
- D. Only Confidentiality

✓ **Answer: C** — Reading credentials violates Confidentiality. If the attacker also modifies traffic (injecting content), Integrity is also violated. Availability is not directly affected.

Q10. Which switch-level feature validates ARP replies against a DHCP snooping binding table and drops mismatches?

- A. WPA-Enterprise
- B. Certificate pinning
- C. Dynamic ARP Inspection (DAI)
- D. HSTS

✓ **Answer: C** — DAI is a Layer 2 switch feature that inspects ARP packets and discards any where the sender's IP/MAC pair does not match the DHCP snooping database — blocking ARP spoofing at the switch.

SECTION 1 — SHORT ANSWER PRACTICE (10 Questions)

SA1. Explain how ARP spoofing enables a MITM attack. Include what an attacker sends and to whom.

Answer: The attacker sends fake gratuitous ARP replies to both the victim and the gateway. Victim reply: 'gateway IP is at attacker MAC.' Gateway reply: 'victim IP is at attacker MAC.' Both update their ARP caches. All traffic between them now routes through the attacker. With IP forwarding enabled the attacker forwards transparently while intercepting/modifying traffic.

SA2. What is a gratuitous ARP and why is it exploited in ARP poisoning?

Answer: A gratuitous ARP is an unsolicited ARP reply sent without a preceding request — a host announces its own IP-to-MAC mapping proactively. ARP has no authentication, so any host can send one claiming any IP. Receiving hosts accept and cache it without verification, making it trivially exploitable.

SA3. Describe SSL stripping and identify which CIA properties it violates.

Answer: Steps: (1) attacker is MITM via ARP spoof; (2) victim makes HTTP request; (3) attacker intercepts before HTTPS redirect; (4) attacker opens valid HTTPS to real server; (5) serves victim plain HTTP; (6) victim submits credentials in cleartext. Violations: Confidentiality (credentials read), Integrity (page content can be modified/injected).

SA4. What is HSTS and how does it prevent SSL stripping?

Answer: HTTP Strict Transport Security (HSTS) is a response header instructing browsers to only use HTTPS for a domain for a set period. HSTS Preloading goes further — domains are hard-coded in browsers, so no HTTP request is ever made. This removes the interception window SSL stripping relies on (the initial HTTP request).

SA5. How does an evil twin differ from a rogue AP? What authentication mechanism defends against it?

Answer: A rogue AP is any unauthorised AP. An evil twin specifically clones the SSID of a legitimate network to trick auto-connect. Defence: WPA-Enterprise (802.1X) — per-user authentication with server certificates.

The client validates the AP's identity cryptographically; an evil twin cannot present a valid signed certificate.

SA6. A network admin sees two different MACs responding to the same IP in Wireshark. What attack is likely occurring and what should they do?

Answer: This is ARP spoofing — two MACs claiming the same IP is the hallmark. Actions: (1) confirm with arp.duplicate-address-detected filter; (2) identify rogue MAC via switch port tables; (3) enable DAI on managed switches; (4) investigate the rogue MAC host; (5) set static ARP entries for critical infrastructure while resolving.

SA7. Why is ARP spoofing limited to local network segments?

Answer: ARP operates at Layer 2 and uses broadcast frames, which routers do not forward. ARP broadcasts are confined to the local broadcast domain (VLAN/subnet). Routers separate broadcast domains, so fake ARP replies cannot reach hosts on different subnets.

SA8. What is DNS cache poisoning and what protocol feature makes it possible?

Answer: DNS cache poisoning inserts a forged DNS record into a resolver's cache, redirecting future queries to an attacker-controlled IP. Possible because: (1) early DNS used predictable 16-bit transaction IDs; (2) DNS over UDP is unauthenticated — the first matching response wins. DNSSEC mitigates this with cryptographic signatures.

SA9. Compare Ettercap and Bettercap as MITM tools.

Answer: Ettercap is an older, established suite for ARP poisoning, sniffing, and plugin-based MITM with GUI and text modes. Bettercap is a modern, actively maintained framework with modular architecture covering ARP, DNS, WiFi, BLE, and a REST API / scripting capability. Bettercap is generally preferred in modern pentesting for its broader attack surface and automation.

SA10. Why does enabling IP forwarding matter during ARP spoofing? What happens if it is not enabled?

Answer: With ARP caches poisoned, all victim-to-gateway traffic arrives at the attacker's machine. Without IP forwarding, the attacker's OS drops the packets — the victim loses connectivity, which is noisy and detectable. With IP forwarding (echo 1 > /proc/sys/net/ipv4/ip_forward on Linux), traffic is forwarded transparently — the attack is invisible to the victim while interception occurs.

SECTION 2 — GDPR & PRIVACY ENGINEERING (Lecture 11)

GDPR personal data data subject data controller data processor lawful basis consent legitimate interest right to erasure right of access data minimisation privacy by design pseudonymisation anonymisation DPO data breach notification DPIA privacy by default purpose limitation

■ 2.1 — What Is GDPR?

The **General Data Protection Regulation (GDPR)** (EU) 2016/679 governs processing of **personal data** of EU/EEA individuals. It has **extraterritorial scope** — applies to any organisation processing EU residents' data regardless of where the organisation is located. Penalties: up to **€20 million or 4% of global annual turnover** (whichever is higher).

Term	Definition
Personal Data	Any information relating to an identified or identifiable natural person. Includes name, IP address, location data, cookie IDs, biometrics.
Data Subject	The natural person whose data is being processed.
Data Controller	Entity that determines the purposes and means of processing. Bears primary GDPR obligations.
Data Processor	Entity processing data on behalf of the controller (e.g. cloud host). Must follow controller instructions.
Processing	Any operation on personal data: collection, recording, storage, use, disclosure, deletion, etc.
Special Category Data	Sensitive data: racial/ethnic origin, political opinions, religious beliefs, biometric/genetic data, health, sexual orientation. Requires extra protection.

■ 2.2 — The 6 Lawful Bases for Processing (Article 6)

Every act of processing personal data **MUST** have ONE lawful basis. If none applies, processing is unlawful.

#	Lawful Basis	Key Condition	Exam Scenario
1	Consent	Freely given, specific, informed, unambiguous. Easy to withdraw.	User ticks a non-pre-ticked box to receive marketing emails.
2	Contract	Necessary to perform a contract with the data subject.	Processing delivery address to ship an order.
3	Legal Obligation	Necessary to comply with EU/member-state law.	Employer processes payroll data for tax reporting.
4	Vital Interests	Necessary to protect someone's life.	Hospital processes data of unconscious accident victim.
5	Public Task	Necessary for official authority / public interest task under law.	Council processes address data for electoral register.
6	Legitimate Interests	Controller's legitimate interest not overridden by data subject's rights. Requires balancing test.	Fraud detection; network security monitoring of employee devices (with notice).

Legitimate Interests tip: LI cannot override data subjects' rights when processing is likely to cause harm or the data subject would not reasonably expect it. A Legitimate Interests Assessment (LIA) / balancing test must be documented.

■ 2.3 — The 8 Data Subject Rights

Right	What It Means	Key Limit
Right of Access (Art. 15)	Request a copy of personal data held and info about how it is used.	Must respond within 1 month (extendable by 2 months for complex cases).
Right to Rectification (Art. 16)	Correct inaccurate personal data.	Also covers completing incomplete data.
Right to Erasure / 'Right to Be Forgotten' (Art. 17)	Request deletion of personal data.	Does NOT apply if processing is for legal obligation, public interest, legal claims, or scientific research.
Right to Restrict Processing (Art. 18)	Pause processing while accuracy is contested or objection pending.	Data can still be stored; only processing is restricted.
Right to Data Portability (Art. 20)	Receive data in structured machine-readable format; transfer to another controller.	Applies only to consent or contract basis, automated processing.
Right to Object (Art. 21)	Object to processing based on legitimate interests or public task. Absolute right to object to direct marketing.	Direct marketing objection must always be honoured.
Rights re: Automated Decisions (Art. 22)	Not be subject to solely automated decisions with significant effects without human review.	Applies to credit scoring, job screening etc.
Right to Withdraw Consent (Art. 7(3))	Withdraw consent at any time without detriment.	Must be as easy to withdraw as to give. Does not affect prior lawful processing.

■ 2.4 — The 7 Data Protection Principles (Article 5)

Principle	Meaning
Lawfulness, Fairness, Transparency	Must have a lawful basis; be fair to individuals; provide clear privacy notice.
Purpose Limitation	Collected only for specified, explicit, legitimate purposes. Cannot be reused for incompatible purposes.
Data Minimisation	Only collect what is adequate, relevant, and necessary for the purpose.
Accuracy	Personal data must be accurate and kept up to date. Inaccurate data must be corrected or deleted.
Storage Limitation	Do not keep data longer than necessary. Retention periods must be defined and enforced.
Integrity and Confidentiality	Appropriate technical and organisational security measures must protect data.
Accountability	Controller must DEMONSTRATE compliance: documentation, policies, DPIAs, records of processing activities.

■ 2.5 — Pseudonymisation vs Anonymisation

Critical GDPR distinction: pseudonymous data is still personal data. Anonymous data is not.

	Pseudonymisation	Anonymisation
Definition	Replace direct identifiers with artificial codes. Re-identification possible with additional key.	Irreversibly remove all identifiers — individual cannot be re-identified even with additional data.
GDPR applies?	YES — still personal data. Treated as a security measure reducing risk.	NO — GDPR does not apply to truly anonymous data. High bar to achieve.
Re-identification	Possible (controller holds mapping key)	Should be impossible (if done correctly)

	Pseudonymisation	Anonymisation
Example	SHA256(name+salt) → hash; key held separately	Aggregate stats: '42% of users aged 25-34' — no individual identifiable
Techniques	Tokenisation, hashing with salt, encryption of identifiers	k-anonymity, l-diversity, differential privacy, data generalisation
Risk	Key compromise re-identifies all records	Residual re-identification risk via linkage attacks on quasi-identifiers

■ 2.6 — Privacy by Design & Privacy by Default (Article 25)

PbD Principle	Meaning
Proactive not Reactive	Anticipate and prevent privacy violations before they occur.
Privacy as the Default	Default settings must offer highest privacy protection — user must actively choose to share more.
Privacy Embedded into Design	Privacy is integral to architecture, not bolted on.
Full Functionality (Positive-Sum)	Privacy AND security AND functionality — not privacy OR the others. Avoid false trade-offs.
End-to-End Security	Secure data for its full lifecycle: collection → use → deletion.
Visibility and Transparency	Operate openly — components and practices are verifiable.
Respect for User Privacy	User-centric: strong defaults, appropriate notice, user-friendly options.

Privacy by Default (Art. 25): only the minimum necessary personal data is processed by default. Opt-in is preferred over opt-out. Examples: social media profiles default to private; location is off by default.

■ 2.7 — DPIA and Breach Notification

DPIA (Art. 35): mandatory for high-risk processing — systematic profiling, special category data at scale, systematic public surveillance. Process: describe processing → assess necessity → assess risks → identify mitigations.

Data Breach Notification (Art. 33–34): (1) notify supervisory authority **within 72 hours** of becoming aware (if risk to individuals); (2) notify affected data subjects **without undue delay** if breach poses HIGH risk to their rights.

DPO: mandatory for public authorities and organisations whose core activities involve large-scale systematic monitoring or processing special category data at scale. Independent, reports to highest management.

SECTION 2 — MCQ PRACTICE (10 Questions)

Q1. A company collects email addresses. The user actively ticked a non-pre-filled box confirming they want newsletters. Which lawful basis applies?

- A. Legitimate interests
- B. Vital interests
- C. Consent
- D. Legal obligation

✓ **Answer: C** — The user freely gave specific, informed, unambiguous consent by actively ticking a box. This is valid GDPR consent under Article 6(1)(a) and Article 7.

Q2. Under GDPR, pseudonymised data is:

- A. Not personal data — GDPR does not apply
- B. Still personal data — GDPR applies, but risk is reduced
- C. Only personal data if the pseudonym is the person's actual name
- D. Exempt from all security requirements

✓ **Answer: B** — Pseudonymisation replaces identifiers with codes but re-identification remains possible. GDPR still applies — pseudonymisation is a security measure, not an exemption.

Q3. A data subject requests deletion of all their personal data. Under which circumstance can the company REFUSE?

- A. The company is very large
- B. Processing is necessary to comply with a legal obligation or for legal claims
- C. The data has been pseudonymised
- D. Data has been processed for more than 1 year

✓ **Answer: B** — The Right to Erasure (Art. 17) has exceptions: legal obligation, legal claims, public interest, scientific research. Company size is irrelevant.

Q4. 'Data minimisation' under GDPR means:

- A. All data must be encrypted at rest
- B. Collect only data that is adequate, relevant, and limited to what is necessary
- C. Data must be deleted after a minimum of 6 months
- D. Personal data must be kept to a minimum of one copy

✓ **Answer: B** — Data minimisation (Art. 5(1)(c)) requires collecting only what is necessary for the stated purpose. Collecting extra data 'just in case' violates this principle.

Q5. A hospital processes medical records of an unconscious accident victim without consent. Which lawful basis applies?

- A. Consent
- B. Contract
- C. Vital interests
- D. Legitimate interests

✓ **Answer: C** — Vital interests (Art. 6(1)(d)) applies when processing is necessary to protect life — the unconscious patient cannot consent, but their life depends on data access.

Q6. Under GDPR breach notification, a controller must notify the supervisory authority within:

- A. 24 hours
- B. 48 hours
- C. 72 hours
- D. 7 days

✓ **Answer: C** — Article 33 requires notification within 72 hours of becoming aware of a breach posing risk to individuals. Late notifications must explain the delay.

Q7. Which Privacy by Design principle rejects the view that privacy and functionality are mutually exclusive?

- A. Proactive not Reactive
- B. End-to-End Security
- C. Full Functionality (Positive-Sum)
- D. Visibility and Transparency

✓ **Answer: C** — Full Functionality / Positive-Sum rejects false trade-offs: privacy, security, and functionality must all be achieved simultaneously.

Q8. A company processes employee emails for fraud detection without informing employees. Which GDPR principle does this most directly violate?

- A. Accuracy
- B. Storage limitation
- C. Data minimisation
- D. Lawfulness, Fairness, and Transparency

✓ **Answer: D** — Processing without informing individuals violates the Transparency component of Art. 5(1)(a). Employees must be told how their data is used.

Q9. The Right to Data Portability (Art. 20) applies ONLY when processing is based on:

- A. Legal obligation or public task
- B. Vital interests or consent
- C. Consent or contract, carried out by automated means
- D. Any lawful basis if the data subject requests it

✓ **Answer: C** — Portability is limited to processing based on consent or contract and carried out by automated means. It does not apply to legal obligation or public task bases.

Q10. An organisation's core activity is large-scale systematic CCTV surveillance of public spaces. Under GDPR, this organisation:

- A. Is exempt since CCTV is a public safety measure
- B. Must appoint a Data Protection Officer (DPO)
- C. Can process under vital interests without consent
- D. Only needs to comply if data is transferred outside the EU

✓ **Answer: B** — Art. 37 requires DPO appointment for organisations whose core activity involves large-scale systematic monitoring — CCTV surveillance at scale is a textbook example.

SECTION 2 — SHORT ANSWER PRACTICE (10 Questions)

SA1. List the 6 lawful bases for processing under GDPR Article 6 with an example for each.

Answer: (1) Consent — opt-in marketing. (2) Contract — processing delivery address. (3) Legal obligation — payroll tax reporting. (4) Vital interests — treating unconscious patient. (5) Public task — electoral register. (6) Legitimate interests — fraud detection, where interest is not overridden by individual's rights.

SA2. Explain the difference between pseudonymisation and anonymisation under GDPR. Which does GDPR apply to?

Answer: Pseudonymisation replaces identifiers with codes; re-identification is still possible using a key. GDPR applies — it is a risk-reducing security measure. Anonymisation irreversibly removes all identifiers; GDPR does NOT apply. The key test: is re-identification possible? If yes, data is pseudonymous, not anonymous.

SA3. A social media platform defaults new profiles to 'public' and makes privacy settings hard to find. Which Privacy by Design principle does this violate?

Answer: 'Privacy as the Default' — one of Cavoukian's 7 PbD principles (codified in GDPR Art. 25). The highest privacy protection must be the default. Users should actively choose to share more, not hunt through settings to limit sharing.

SA4. What is a DPIA, when is it mandatory, and what does it involve?

Answer: A Data Protection Impact Assessment (Art. 35) is a structured risk assessment of high-risk processing before it begins. Mandatory for: systematic profiling, special category data at scale, systematic public surveillance. Involves: (1) describe the processing; (2) assess necessity and proportionality; (3) identify risks to individuals; (4) identify mitigations.

SA5. A user requests deletion. The company refuses because they want the data 'for future analysis'. Is this lawful?

Answer: No. 'Future analysis' is not a valid exception to the Right to Erasure (Art. 17). Valid exceptions include legal obligation, legal claims, public interest, and genuine scientific research. Vague business reasons do not override an erasure request.

SA6. What are the 7 data protection principles under GDPR Article 5?

Answer: (1) Lawfulness, Fairness, Transparency. (2) Purpose Limitation. (3) Data Minimisation. (4) Accuracy. (5) Storage Limitation. (6) Integrity and Confidentiality. (7) Accountability — controller must demonstrate compliance with all principles.

SA7. Explain k-anonymity and give an example of why it may not be sufficient.

Answer: k-anonymity ensures each record is indistinguishable from at least k-1 others based on quasi-identifiers. Failure example: if k=3 for (35, Male, SW1) but all three have the same sensitive attribute (HIV-positive), an attacker still learns that attribute about the specific person — the homogeneity attack. l-diversity and t-closeness address this.

SA8. A US startup processes personal data of EU citizens via its website. Does GDPR apply?

Answer: Yes. GDPR has extraterritorial scope (Art. 3). It applies to any organisation processing EU residents' data when offering goods/services to EU individuals or monitoring their behaviour — both apply here. The startup must comply, may need to appoint an EU representative, and can face EU supervisory authority enforcement.

SA9. What is the difference between a data controller and a data processor? Give an example of each.

Answer: Controller: determines WHY and HOW data is processed — primarily accountable under GDPR. Example: a hospital deciding to store patient records digitally. Processor: processes data on behalf of the controller, following their instructions. Example: AWS storing the hospital's data. A Data Processing Agreement (DPA) is required between them.

SA10. Describe two scenarios where data portability applies and one where it does not.

Answer: Applies: (1) User exports Spotify listening history in JSON to move to a competitor — contract basis, automated. (2) Export fitness app health data — consent basis, automated. Does NOT apply: Tax authority holds your records under legal obligation — portability requires consent OR contract, not legal obligation.

SECTION 3 — STRIDE THREAT MODEL & DREAD SCORING (Lectures 8/12)

STRIDE DREAD Spoofing Tampering Repudiation Information Disclosure Denial of Service Elevation of Privilege DFD Data Flow Diagram trust boundary threat model attack tree mitigation

3.1 — STRIDE Overview

STRIDE is a threat classification framework developed by Microsoft used in threat modelling to systematically identify potential threats. Applied to elements in a **Data Flow Diagram (DFD)**: processes, data stores, data flows, and external entities.

Letter	Threat	Violated Property	Definition	Example
S	Spoofing	Authentication	Pretending to be someone/something you are not.	Stolen credentials; IP address spoofing.
T	Tampering	Integrity	Modifying data or code without authorisation.	MITM data modification; database record alteration; code injection.
R	Repudiation	Non-repudiation	Denying an action was performed; system cannot disprove it.	User denies a transaction; log deletion to cover tracks.
I	Information Disclosure	Confidentiality	Exposing data to unauthorised parties.	Unencrypted traffic; SQL injection revealing DB contents; misconfigured S3.
D	Denial of Service	Availability	Disrupting service so legitimate users cannot access it.	SYN flood; DDoS; Slowloris; resource exhaustion.
E	Elevation of Privilege	Authorisation	Gaining capabilities beyond what is authorised.	Buffer overflow → root; privilege escalation via misconfigured sudo; container escape.

3.2 — STRIDE-to-Mitigation Mapping

Threat (STRIDE)	Standard Mitigations
Spoofing (S)	Strong authentication (MFA, certificates); anti-spoofing filters (ingress/egress); OAuth 2.0 / OIDC; Kerberos; short-lived session tokens.
Tampering (T)	Integrity checks (HMAC, digital signatures); TLS for data in transit; access controls on databases; input validation; file integrity monitoring (Tripwire).
Repudiation (R)	Tamper-evident centralised audit logs (write-once, SIEM-forwarded); digital signatures; timestamps; logs not deletable by local admin.
Information Disclosure (I)	Encryption at rest and in transit (TLS 1.3, AES-256); least-privilege access control; data minimisation; proper error handling (no stack traces to users); DLP.
Denial of Service (D)	Rate limiting; CAPTCHAs; CDN / DDoS scrubbing (Cloudflare); SYN cookies; redundancy / failover; resource quotas; firewall ACLs.
Elevation of Privilege (E)	Least privilege; mandatory access control (SELinux, AppArmor); regular patching; input validation; container security (no root containers); RBAC.

3.3 — DFD Elements and STRIDE Applicability

DFD Element	Description	Applicable STRIDE Threats
External Entity	User, browser, external system — data origin/destination	Spoofing, Repudiation
Process	Code/application that transforms data	All 6 STRIDE categories
Data Store	Database, file, cache — data at rest	Tampering, Repudiation, Information Disclosure, DoS
Data Flow	Data moving between elements (arrow)	Tampering, Information Disclosure, DoS
Trust Boundary	Line separating zones of different trust (e.g. internet/DMZ)	All threats elevated when a flow crosses a trust boundary

■ 3.4 — DREAD Risk Scoring

DREAD prioritises threats. Each of 5 dimensions scored 1–10; scores are averaged. Higher score = higher priority to mitigate.

Factor	Question	Low (1-3)	Medium (5)	High (8-10)
Damage (D)	How much damage if exploited?	Dummy data disclosed	Sensitive data leaked; service degraded	Full admin compromise; data destruction
Reproducibility (R)	How reliably can the attack be reproduced?	Requires unique rare conditions	Reproducible in specific conditions	Works every time, from anywhere
Exploitability (E)	How easy to launch the attack?	Advanced skills + insider access	Requires tools and some expertise	Novice can exploit with a script
Affected Users (A)	What proportion of users are impacted?	1 or very few users	Some users or admin only	All users / entire customer base
Discoverability (D)	How easy is it to find the vulnerability?	Not in public databases	Findable by skilled researcher	Obvious; public exploit available

DREAD worked example — SQL Injection on login form:

Factor	Score	Reasoning
Damage (D)	9	Full dump of all user credentials, PII, possibly payment data.
Reproducibility (R)	9	SQL injection is deterministic — same payload, same result every time.
Exploitability (E)	8	Simple string injection; sqlmap automates it completely.
Affected Users (A)	10	Every registered user's data is exposed — entire user base.
Discoverability (D)	7	Login forms are the first thing attackers probe; SQLi is in OWASP Top 10.
DREAD Score	$(9+9+8+10+7)/5 = 8.6 / 10 \rightarrow$ HIGH RISK	Immediate priority: parameterised queries, WAF, penetration test.

■ 3.5 — Attack Trees

An **attack tree** hierarchically represents how an attacker achieves a goal. **Root**: ultimate goal. **AND nodes**: all children must be satisfied. **OR nodes**: any one child is sufficient. Leaves are basic attack steps. Uses: enumerate ALL paths to a goal, identify cheapest/easiest path to cut, prioritise defences, communicate risk to stakeholders.

Example — root goal: 'Gain unauthorised access to corporate database':

OR: (1) SQL injection via web app | (2) Stolen admin credentials | (3) Direct network access (firewall bypass)

Branch (1) AND: Vulnerable input field AND attacker can reach web app AND WAF can be bypassed

Branch (2) OR: Phishing | Brute force | Purchase on dark web

SECTION 3 — MCQ PRACTICE (10 Questions)

Q1. In STRIDE, which threat category most directly violates Non-repudiation?

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Information Disclosure

✓ **Answer: C** — Repudiation (R) is the threat where an entity denies performing an action and the system cannot prove it. Mitigations include audit logs and digital signatures.

Q2. An attacker exploits a buffer overflow to gain root access. Which STRIDE category applies?

- A. Spoofing
- B. Tampering
- C. Denial of Service
- D. Elevation of Privilege

✓ **Answer: D** — Gaining root from a non-root context is Elevation of Privilege (E) — acquiring capabilities beyond authorisation, violating Authorisation.

Q3. A data flow (arrow in a DFD) is subject to which STRIDE categories?

- A. All six
- B. Spoofing, Repudiation, Information Disclosure, DoS
- C. Tampering, Information Disclosure, DoS
- D. Only Tampering and DoS

✓ **Answer: C** — Data flows are subject to Tampering (modifying data in transit), Information Disclosure (eavesdropping), and DoS (blocking the flow). Spoofing and EoP apply to processes/entities.

Q4. In DREAD, 'Exploitability' measures:

- A. How many users are affected
- B. How much damage is caused
- C. How easy it is to launch the attack
- D. How publicly known the vulnerability is

✓ **Answer: C** — Exploitability (E) scores the ease of attack execution — from requires advanced skills (low) to anyone can exploit with a browser (high).

Q5. A trust boundary in a DFD represents:

- A. Maximum data throughput of a component
- B. A line separating zones of different trust levels, e.g. internet and DMZ
- C. The time limit for a security token
- D. The boundary of a cryptographic key's validity

✓ **Answer: B** — Trust boundaries separate zones with different trust levels. Threats are especially significant when data flows cross them — every such crossing should be scrutinised.

Q6. An attacker floods a web server with half-open TCP connections (SYN flood). Which STRIDE category applies?

- A. Tampering
- B. Repudiation

C. Elevation of Privilege

D. Denial of Service

✓ **Answer: D** — A SYN flood exhausts the server's connection table with half-open connections, preventing legitimate connections — classic DoS, violating Availability.

Q7. A DREAD Exploitability score of 2 most likely means:

A. Only 2 users are affected

B. Very hard to exploit — requires specialist knowledge or unique rare conditions

C. The vulnerability is 2 years old

D. Two different attack vectors exist

✓ **Answer: B** — Low Exploitability indicates the attack is difficult to launch — requires advanced skills, insider knowledge, or very specific rare conditions.

Q8. Which mitigation most directly addresses the STRIDE 'Repudiation' threat?

A. TLS encryption of all traffic

B. Tamper-evident centralised audit logging forwarded to SIEM

C. Rate limiting on API endpoints

D. Input validation and parameterised queries

✓ **Answer: B** — Repudiation is countered by non-repudiation measures — tamper-evident audit logs that cannot be altered by users or even local admins.

Q9. An external entity in a DFD is primarily threatened by which STRIDE categories?

A. Tampering and DoS only

B. Information Disclosure and EoP only

C. Spoofing and Repudiation

D. All six categories equally

✓ **Answer: C** — External entities (users, external systems) are primarily subject to Spoofing (impersonating the entity) and Repudiation (denying they sent a request).

Q10. The primary purpose of an attack tree in threat modelling is to:

A. Store hashed passwords in a tree structure

B. Enumerate all attack paths to a goal and prioritise defences

C. Define physical network topology

D. Certify a system is secure against all known attacks

✓ **Answer: B** — Attack trees map all attacker paths (AND/OR) from basic steps to the ultimate goal. They identify cheapest paths to cut and help prioritise defences — but never certify complete security.

SECTION 3 — SHORT ANSWER PRACTICE (10 Questions)

SA1. What does STRIDE stand for, and what security property does each letter violate?

Answer: S=Spoofing (Authentication), T=Tampering (Integrity), R=Repudiation (Non-repudiation), I=Information Disclosure (Confidentiality), D=Denial of Service (Availability), E=Elevation of Privilege (Authorisation).

SA2. Explain how STRIDE is applied to a Data Flow Diagram.

Answer: A DFD has External Entities (origins/destinations), Processes (transforms), Data Stores (databases/files), Data Flows (arrows), and Trust Boundaries. For each element, relevant STRIDE categories are checked: External Entities → S, R; Data Flows → T, I, D; Data Stores → T, R, I, D; Processes → all 6. This produces a structured list of threats per component.

SA3. Calculate the DREAD score: D=9, R=10, E=10, A=8, D=8. What priority is this?

Answer: $DREAD = (9+10+10+8+8)/5 = 45/5 = 9.0$. CRITICAL/HIGH risk. Immediate remediation required: e.g. change default credentials, restrict admin interface to management VLAN, enable MFA.

SA4. What is the difference between AND and OR nodes in an attack tree?

Answer: AND node: ALL children must be satisfied for the parent goal. OR node: ANY ONE child is sufficient. AND nodes represent harder attacks (must do everything); OR nodes provide multiple independent attack paths. Security must address all OR branches — leaving even one open allows the attack.

SA5. Give a concrete STRIDE example for each category applied to a web application login system.

Answer: S: stolen session cookie impersonates user. T: attacker modifies POST params to change role to admin. R: user denies purchase; no signed audit log proves they did it. I: error shows stack trace revealing DB schema. D: thousands of login attempts exhaust server threads. E: SQLi lets attacker INSERT admin account.

SA6. Why is DREAD's 'Discoverability' factor sometimes criticised?

Answer: Security through obscurity is unreliable — assuming a vulnerability is hard to find does not make it safe. Sophisticated attackers assume every vulnerability will eventually be discovered. Some organisations remove Discoverability from DREAD or replace it. CVSS (Common Vulnerability Scoring System) is a more standardised industry alternative.

SA7. What is a trust boundary in threat modelling and why is it important?

Answer: A trust boundary separates zones with different trust levels — e.g. internet vs. DMZ, DMZ vs. internal, user space vs. kernel. Data crossing a boundary is at elevated risk for all STRIDE threats. Every data flow crossing a boundary should be scrutinised for authentication, encryption, and validation.

SA8. What makes a threat model a 'living document' and why should it be updated?

Answer: A threat model captures threats at a point in time. Systems change: new features add attack surface, dependencies change, new threat actors emerge, attacker techniques evolve. Update triggers: architectural changes, major releases, security incidents, new CVEs, periodic reviews. Shostack's 4 questions: What are we building? What can go wrong? What are we doing about it? Did we do a good job?

SA9. Compare STRIDE and DREAD — what does each contribute?

Answer: STRIDE identifies and classifies threats (WHAT can go wrong) applied to DFD elements. DREAD scores identified threats to prioritise them (WHICH to fix first). STRIDE answers 'what can go wrong?'; DREAD answers 'how bad is it?'. Used together: STRIDE to find, DREAD to prioritise.

SA10. An attacker accesses a web app process and reads env vars containing database connection strings. Map to STRIDE and suggest mitigations.

Answer: Information Disclosure (I) — attacker reads confidential secrets. Potentially also EoP if the DB connection allows admin access. Mitigations: (1) use secrets manager (Vault, AWS Secrets Manager) not env vars; (2) least-privilege DB accounts; (3) encrypt secrets at rest; (4) runtime monitoring (Falco) to detect suspicious reads; (5) container hardening — read-only filesystem, no root processes.

SECTION 4 — KUBERNETES THREAT MODELLING (Lecture 12)

Kubernetes K8s 4Cs Cloud Cluster Container Code Pod API server etcd kubelet RBAC namespace network policy container escape privilege escalation service account secret image scanning admission controller Falco OPA Gatekeeper

■ 4.1 — Kubernetes Architecture (Exam Context)

Component	Role	Security Significance
API Server	Central control plane — all commands flow through it; authenticates and authorises requests	Compromise = full cluster control; TLS-only, RBAC enforced
etcd	Distributed key-value store holding ALL cluster state and secrets	Compromise = read all secrets; encrypt at rest; not internet-accessible
kubelet	Agent on each node; runs Pods; communicates with API server	Unauthenticated kubelet port 10250 = full node compromise
Pod	Smallest deployable unit; contains one or more containers	Container escape from Pod can reach node then cluster
Namespace	Virtual cluster for resource isolation within K8s	Not a security boundary without Network Policies
Service Account	Identity for Pods to authenticate to the API server	Over-privileged SA = attacker in Pod gets cluster admin
Secrets	K8s objects storing sensitive data (passwords, tokens, TLS certs)	Not encrypted by default in etcd; must enable encryption at rest
Network Policy	Rules controlling Pod-to-Pod and external traffic	Without policies, all Pods can talk to each other by default
Admission Controller	Validates/mutates API requests before objects are created	OPA/Gatekeeper enforces policy — deny privileged containers

■ 4.2 — The 4Cs of Cloud-Native Security

Four nested security layers. Security is only as strong as the weakest layer. A compromise at an outer layer undermines all inner layers regardless of inner-layer controls.

Layer	Scope	Example Threats	Key Controls
Cloud	Underlying infrastructure: VMs, managed K8s (EKS/GKE/AKS), cloud IAM, storage	Misconfigured IAM; exposed etcd endpoint; SSRF to metadata service	Least-privilege IAM; private cluster endpoint; firewall rules; CSPM
Cluster	K8s control plane: API server, etcd, kubelet, RBAC, network policies	Unauthenticated API; excessive RBAC; no network policies; exposed kubelet :10250	RBAC; API server auth/authz; etcd encryption; network policies; audit logging
Container	Container runtime, images, isolation: seccomp, AppArmor, cgroups	Vulnerable base image; running as root; privileged container; container escape	Non-root containers; image scanning (Trivy); seccomp/AppArmor; no privileged containers
Code	Application code and dependencies: libraries, APIs, secrets handling	SQL injection; RCE via library CVE; hardcoded secrets; insecure dependency	SAST/DAST; dependency scanning (Snyk); secrets manager; secure coding

■ 4.3 — Attack Path: Compromised Container → Cluster Takeover

Know each step, what enables it, and what stops it.

Step	Action	What Enables It	Mitigation
1	Initial access: exploit app in Pod	Unpatched library (RCE CVE); SQL injection	Patch deps; DAST; WAF; input validation
2	Container escape to node	Privileged container; CAP_SYS_ADMIN; host path mounts; kernel exploit	No privileged containers; drop capabilities; read-only filesystem; seccomp/AppArmor
3	Node compromise: root on host	Escape gives node root; kubelet runs as root	gVisor / Kata containers; node hardening; minimal node OS
4	Lateral movement to other Pods/nodes	No Network Policies (all Pods can talk by default)	Network Policies (default-deny); namespace isolation; separate node pools
5	Read Service Account token	Auto-mounted SA tokens in every Pod at /var/run/secrets/.../token	Disable auto-mounting; minimal RBAC on SAs
6	Call API server with SA token	Over-privileged RBAC role = cluster admin access	Least-privilege RBAC; audit API logs; short-lived tokens
7	Cluster takeover: read all secrets, deploy backdoor	cluster-admin API access	RBAC audit; OPA/Gatekeeper; alert on cluster-admin binding creation; etcd encryption

■ 4.4 — STRIDE Applied to Kubernetes

STRIDE	K8s Threat	Mitigation
Spoofing (S)	Attacker uses stolen SA token to impersonate legitimate Pod identity to API server	Short-lived tokens; OIDC; MFA for human users; audit logs
Tampering (T)	etcd access → modify cluster state (change Deployment image to malicious one)	etcd TLS + auth; not internet-accessible; OPA validates mutations; GitOps
Repudiation (R)	Malicious admin creates backdoor then deletes API audit logs	Off-cluster immutable audit log storage; alert on log deletion
Info Disclosure (I)	Read Secrets from etcd (unencrypted at rest); env vars expose DB passwords	Encrypt Secrets at rest; secrets manager (Vault); no secrets in env vars
Denial of Service (D)	Deploy resource-hungry crypto miner Pod consuming all node CPU, starving workloads	ResourceQuota per namespace; LimitRange; HPA; network egress rate limits
Elevation of Privilege (E)	Container escape + privileged SA token → bind cluster-admin to attacker account	No privileged containers (OPA); RBAC least privilege; Pod Security Admission

■ 4.5 — Kubernetes Hardening Checklist

Control Plane:

- Enable API server RBAC auth/authz (not ABAC); disable anonymous auth (--anonymous-auth=false)
- Restrict API server access to management VLAN / VPN — not internet-accessible
- Enable etcd encryption at rest (--encryption-provider-config)
- Enable API server audit logging; ship logs off-cluster to immutable store

Workload Security:

- Never run containers as root — use runAsUser: 1000+
- Set allowPrivilegeEscalation: false and readOnlyRootFilesystem: true

- Drop all capabilities; add only what is needed (drop: [ALL]; add: [NET_BIND_SERVICE])
- Disable SA token auto-mounting: automountServiceAccountToken: false
- Scan images before deployment: **Trivy**, Gype, Snyk Container

Network:

- Default-deny Network Policies — allow only required paths for ingress and egress
- Namespace isolation; mTLS between services via service mesh (Istio / Linkerd)

Runtime Detection:

- **Falco** (eBPF): detects shell spawned in container, /etc/shadow reads, unexpected network connections
- **OPA Gatekeeper**: enforce policies — block privileged containers, enforce trusted image registries

4.6 — Key Kubernetes Trust Boundaries

Trust Boundary	Separation	Key Risk if Unconstrained
Internet ↔ Ingress	Public traffic vs. cluster ingress controller	Direct Pod exposure; DDoS; app vulnerability exploitation
Ingress ↔ App Pod	Load-balanced traffic vs. application Pod	App-layer attacks: SQLi, XSS, RCE
Pod ↔ Pod (cross-namespace)	Pods in different namespaces	Without Network Policies: lateral movement between tenants
Container ↔ Node	Container isolation boundary	Container escape gives node root — most critical boundary
Node ↔ API Server	Node kubelet communicates with control plane	Compromised node can query API; kubelet must authenticate
API Server ↔ etcd	Control plane internal	etcd only accepts connections from API server; not exposed externally

SECTION 4 — MCQ PRACTICE (10 Questions)

Q1. In the 4Cs model, which layer addresses Kubernetes RBAC, Network Policies, and etcd encryption?

- A. Cloud
- B. Cluster
- C. Container
- D. Code

✓ **Answer: B** — Cluster covers K8s control plane security: RBAC, API server authentication, etcd security, network policies, and audit logging.

Q2. An attacker in a compromised Pod finds a cluster-admin SA token. What can they do?

- A. Only read Secrets in the current namespace
- B. Read and write any resource in the entire cluster, including creating new admin accounts
- C. Only restart Pods in the current namespace
- D. Nothing — tokens cannot be used outside the Pod

✓ **Answer: B** — A cluster-admin SA token grants full API server access across all namespaces. The attacker can read all Secrets, modify RBAC, deploy malicious containers, and create persistent backdoor admin accounts.

Q3. Which K8s component stores ALL cluster state including Secrets and is therefore a critical attack target?

- A. kubelet
- B. kube-proxy
- C. etcd
- D. CoreDNS

✓ **Answer: C** — etcd holds the entire cluster state including all Secrets (base64-encoded, not encrypted by default). Compromising etcd gives an attacker all credentials and configuration for the whole cluster.

Q4. A Pod runs with securityContext: privileged: true. What does this enable?

- A. The Pod gets more CPU — no security risk
- B. The Pod gets root-level host access and can trivially escape the container
- C. The Pod can only access its own namespace's Secrets
- D. The Pod bypasses resource limits but stays container-isolated

✓ **Answer: B** — A privileged container disables almost all container isolation — full access to host devices, can mount host filesystems, and trivially escapes to the node.

Q5. Which tool provides eBPF-based runtime security detecting threats like shells spawned inside a container?

- A. Trivy
- B. OPA Gatekeeper
- C. Falco
- D. Snyk

✓ **Answer: C** — Falco monitors system calls at the node level, detecting runtime anomalies like unexpected process spawning, sensitive file access (/etc/shadow), or unexpected network connections.

Q6. The 'Container' layer of the 4Cs focuses on:

- A. Kubernetes RBAC and network policies
- B. Application code security
- C. Container images, runtime isolation, and security profiles
- D. Cloud IAM and infrastructure

✓ **Answer: C** — Container layer covers image security (scanning, trusted registries), runtime isolation (seccomp, AppArmor, capabilities), and whether containers run as root.

Q7. An attacker uses a compromised kubelet to modify cluster Deployment specs. Which STRIDE category?

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Denial of Service

✓ **Answer: B** — Modifying cluster state is Tampering (T) — unauthorised modification of data or system state, violating Integrity.

Q8. Why does disabling automountServiceAccountToken for Pods that don't need API server access improve security?

- A. It prevents the Pod from accessing the internet
- B. It removes a high-value credential an attacker could use for lateral movement or cluster takeover
- C. It increases the Pod's CPU allocation
- D. It prevents the Pod from being scheduled on compromised nodes

✓ **Answer: B** — By default, every Pod gets a SA token at a well-known path. An attacker in a compromised Pod will immediately look for it. Disabling automounting removes this attack path entirely.

Q9. A Network Policy of 'default-deny all ingress and egress' means:

- A. The cluster cannot receive internet traffic
- B. All Pod-to-Pod and Pod-to-external communication is blocked unless explicitly permitted
- C. The API server is shut down
- D. etcd is encrypted

✓ **Answer: B** — Default-deny blocks all inbound/outbound traffic for Pods in the namespace unless a specific policy explicitly allows it — enforcing least-privilege networking.

Q10. An attacker runs a crypto miner in a compromised Pod, consuming all node CPU and evicting other Pods. Which STRIDE category?

- A. Tampering
- B. Spoofing
- C. Denial of Service
- D. Information Disclosure

✓ **Answer: C** — Consuming all resources to deny service to legitimate workloads is DoS (D). Mitigations: ResourceQuota per namespace, LimitRange on Pods.

SECTION 4 — SHORT ANSWER PRACTICE (10 Questions)

SA1. Describe the 4Cs of cloud-native security and explain why each layer's security depends on outer layers.

Answer: 4Cs: Cloud (infrastructure), Cluster (K8s control plane), Container (runtime), Code (application). They are nested — a compromise at an outer layer undermines inner layers regardless. Example: excellent RBAC (Cluster) is irrelevant if etcd is internet-accessible (Cloud flaw). Each layer must be secured independently; compromise at any layer should be contained by the others.

SA2. Explain the step-by-step attack path from container compromise to full cluster takeover.

Answer: 1. Exploit vulnerable app in Pod (RCE). 2. Container escape — privileged container or kernel exploit → node root. 3. Node compromise — host filesystem/network access. 4. Lateral movement — no Network Policies means all Pods reachable. 5. Read auto-mounted SA token. 6. Call API server — over-privileged RBAC = cluster admin. 7. Read all Secrets, create backdoor admin, deploy malicious workloads.

SA3. What is etcd and why must it have encryption at rest and restricted network access?

Answer: etcd is K8s' distributed key-value store holding ALL cluster state including Secrets (base64-encoded, not encrypted by default). An attacker with etcd access reads every Secret (credentials, TLS keys, API tokens) for the entire cluster and can modify or corrupt state. Encryption at rest (--encryption-provider-config) protects Secrets if the filesystem is accessed. Network restriction ensures only the API server can query etcd.

SA4. What is a privileged container and why is it dangerous?

Answer: privileged: true disables most container isolation — the container gets access to all host devices, can mount host filesystems, modify kernel parameters, and load kernel modules. From a privileged container, escaping to the host node is trivial. Mitigations: OPA/Gatekeeper policy denying privileged:true; Pod Security Admission restricted profile.

SA5. Explain how Falco improves K8s runtime security. Give 3 detection examples.

Answer: Falco uses eBPF/kernel module to monitor system calls in real time, detecting post-compromise anomalies after static controls are bypassed. Examples: (1) Shell spawned in container (execve /bin/bash) — interactive attacker. (2) Read of /etc/shadow — credential theft. (3) Unexpected outbound connection from container — C2 callback or exfiltration. Alerts can feed a SIEM.

SA6. Why is namespace isolation alone not a strong security boundary in Kubernetes?

Answer: Namespaces provide naming scope and resource quotas but NOT network isolation by default. Without Network Policies, all Pods across all namespaces communicate freely. Strong isolation requires: (1) Network Policies (default-deny); (2) RBAC scoped to namespaces; (3) separate node pools for sensitive workloads; (4) Pod Security Admission at the namespace level.

SA7. What is OPA Gatekeeper and how does it enforce K8s security policies?

Answer: OPA Gatekeeper is an admission controller that evaluates API requests against custom policies written in Rego. Before any K8s object is created/modified, Gatekeeper checks it. Example policies: deny privileged:true; require images from approved registries only; require resource limits; deny Pods running as root (runAsUser: 0). Non-compliant objects are rejected with an informative error.

SA8. Apply STRIDE to the Kubernetes API server — one threat and mitigation per category.

Answer: S: stolen SA token → impersonate cluster-admin — mitigation: short-lived tokens, OIDC, MFA. T: attacker modifies ClusterRoleBinding to grant admin — mitigation: OPA policy; GitOps for RBAC. R: admin creates backdoor, deletes audit logs — mitigation: off-cluster immutable audit storage. I: API returns full Secret contents to over-privileged caller — mitigation: least-privilege RBAC; audit Secret reads. D: flood API with requests — mitigation: rate limiting (--max-requests-inflight); APF. E: exploit API server vulnerability for node root — mitigation: patch; network-restrict access.

SA9. What is RBAC least privilege in Kubernetes and how is it implemented?

Answer: Each SA, user, and group gets only minimum permissions needed. Implementation: (1) Use Roles (namespace-scoped) not ClusterRoles where possible; (2) specify resources and verbs explicitly — no wildcards; (3) disable cluster-admin for all SAs; (4) separate SA per microservice; (5) audit with: `kubectl auth can-i --as system:serviceaccount:ns:sa get secrets --all-namespaces`; (6) use rbac-tool or Polaris to detect over-privilege.

SA10. Describe three controls that prevent or detect container escape.

Answer: (1) Seccomp profiles: restrict which system calls the container can make — escapes typically require privileged syscalls (unshare, mount, ptrace). (2) AppArmor/SELinux: mandatory access control further restricting process actions even as root — kernel enforced. (3) gVisor/Kata Containers: gVisor interposes a user-space kernel between container and host kernel so an exploit hits gVisor, not the real kernel; Kata runs containers in lightweight VMs requiring a full VM escape. Detection: Falco alerting on unexpected syscalls or host namespace access.

Cyber-Additions Reference — End of Document

Section	Topics	MCQs	Short Answers
1 — MITM & Network Interception	ARP spoofing · DNS hijacking · SSL stripping · Rogue AP · Tools · Defences	10	10
2 — GDPR & Privacy Engineering	6 Lawful Bases · 8 Rights · 7 Principles · PbD · Pseudonymisation · DPIA	10	10
3 — STRIDE & DREAD	Full STRIDE table · Mitigation map · DFD · DREAD scoring · Attack trees	10	10
4 — Kubernetes Threat Modelling	4Cs · Architecture · Attack path · K8s STRIDE · Hardening · Trust bounds	10	10
TOTAL		40	40

Use Ctrl+F to find any term, attack name, tool, or principle.